SECURITY CONTROLS & RISK ASSESSMENT

ISO/IEC 27001:2022
Security Controls Gap Assessment

SecurePay Technologies Pvt. Ltd.

Annex A controls assessment, risk assessment, Statement of Applicability and prioritised remediation roadmap

CLIENT	SecurePay Technologies Pvt. Ltd. (fictional organisation)
REPORT DATE	27 October 2026
VERSION	1.0 (Final)
PREPARED BY	Abhishek
CLASSIFICATION	Confidential - illustrative portfolio document

Important notice. This is a **self-directed assessment of a fictional organisation**, prepared as an academic and portfolio exercise. It is **not a real client engagement**. SecurePay Technologies, its people, systems, incidents and findings are invented, and the current state is based on assumed conditions. No interviews, system access or evidence sampling were performed. ISO/IEC 27001:2022 requirements are paraphrased; refer to the licensed standard for authoritative text.

About this document

Document control

Version	Date	Author	Description
0.1	06 October 2026	Abhishek	Scoping and organisation profile
0.9	20 October 2026	Abhishek	Draft findings, risk register and SoA
1.0 (Final)	27 October 2026	Abhishek	Final report with remediation roadmap

Intended distribution (illustrative)

Role	Purpose
CEO (report sponsor)	Approval of roadmap, risk treatment and risk acceptance decisions
CTO (interim security owner)	Ownership of technical remediation
Head of Legal & Compliance	DPDP, RBI and contractual obligations
Board / investors (summary only)	Oversight of security risk and certification plans

Basis of preparation

This report presents a security controls gap assessment and risk assessment of SecurePay Technologies against ISO/IEC 27001:2022. It is a self-directed exercise prepared by the author for learning and portfolio purposes. SecurePay is a fictional organisation; its profile, systems, incidents and current state are realistic assumptions for an early-stage Indian fintech and are listed in Appendix C. It is not based on a real client engagement, and no real organisation's information was used.

Control requirements are paraphrased in plain English and do not reproduce the text of ISO/IEC 27001 or ISO/IEC 27002. Readers who need the authoritative requirements should consult the licensed standards. References to Indian laws, RBI directions, CERT-In directions and PCI DSS are summaries for context and are not legal advice.

All tables and charts are generated from the CSV files in the project's data/ folder by scripts/build_report.py, so the report, the data and the README stay consistent.

Contents

1. Executive summary . . . 4

2. Scope, objectives and methodology . . . 6

2.1 Objectives . . . 6

2.2 Scope . . . 6

2.3 Assessment approach . . . 6

2.4 Rating scales . . . 7

2.5 Limitations . . . 7

3. Organisation overview . . . 8

3.1 Key information assets . . . 8

3.2 Principal data flows . . . 8

3.3 Regulatory and contractual obligations . . . 8

3.4 Stakeholders and interested parties . . . 9

4. Maturity overview . . . 10

5. Clauses 4–10 summary . . . 11

6. Detailed Annex A findings . . . 12

6.1 Organizational controls (A.5) . . . 13

6.2 People controls (A.6) . . . 17

6.3 Physical controls (A.7) . . . 19

6.4 Technological controls (A.8) . . . 20

7. Risk assessment . . . 24

7.1 Risk register summary . . . 24

7.2 Risk scenarios and treatment plans . . . 25

8. Statement of Applicability . . . 27

8.1 Exclusions . . . 27

9. Prioritised remediation roadmap . . . 28

9.1 Phase 1 - Quick wins (0–3 months) . . . 28

9.2 Phase 2 - Build core processes (3–6 months) . . . 28

9.3 Phase 3 - Mature and certify (6–12 months) . . . 29

10. Conclusion . . . 30

Appendix A - Rating definitions . . . 31

Appendix B - Statement of Applicability (all 93 controls) . . . 32

Appendix C - Assumptions . . . 35

Appendix D - Glossary . . . 35

1. Executive summary

SecurePay Technologies Pvt. Ltd. ('SecurePay') is a 50-person Bengaluru fintech that processes online card and UPI payments for about 1,200 small and medium merchants as an RBI-authorised (in-principle) online Payment Aggregator. It is preparing for PCI DSS v4.0.1 assessment and DPDP Act readiness, and its partner banks increasingly ask for ISO/IEC 27001 assurance. This self-directed gap assessment examined 20 Annex A controls across all four 2022 themes, reviewed management-system Clauses 4–10, built a risk register for the top eight information security risks and drafted a Statement of Applicability (SoA) for all 93 Annex A controls.

20	47.5%	1.7 / 5	6	6 of 8
Annex A controls assessed in detail	Conformance score (partial = half credit)	Average maturity (target 3.0)	Non-conformant controls	Top risks rated High or Critical

Overall maturity: Developing

Of the 20 controls assessed, 5 (25%) are conformant, 9 (45%) are partially conformant and 6 (30%) are non-conformant. Average control maturity is 1.7 on a 0–5 scale, between 'Initial' and 'Repeatable'. This is typical for a fast-growing start-up: good engineering habits and cloud-native foundations, but no formal Information Security Management System (ISMS). Security depends on a few capable individuals rather than on approved policies, assigned roles, risk-based planning and monitoring. Clauses 6 (Planning), 9 (Performance evaluation) and 10 (Improvement) are not yet in place, so SecurePay is not currently ready for certification.

Headline findings

- **Privileged access is the most serious gap (Critical).** Five engineers hold permanent AWS administrator rights, the root account and the production database superuser are shared, and privileged activity is neither reviewed nor monitored (A.8.2).
- **Attacks would likely go unnoticed and unreported.** Security logs are not monitored, GuardDuty is off and there is no incident response plan. A real credential-stuffing attack in March 2026 was found only through a merchant complaint after about 19 hours, well beyond CERT-In's 6-hour reporting window (A.8.16, A.5.24).
- **Customer personal data is exposed through the support vendor.** The outsourced BPO uses shared logins without MFA, was never security-assessed and has no security clauses in its contract (A.5.19, A.8.5).
- **DPDP Act readiness is low.** There is no personal data inventory, retention schedule, rights handling or breach notification procedure, and production data is copied into staging (A.5.34).
- **Application security lags the platform's risk.** Four High VAPT findings have been open for nine months and nine hard-coded secrets were found in source code history (A.8.8, A.8.28).
- **There are real strengths to build on.** Encryption and tokenisation (A.8.24), tested cross-region backups (A.8.13), background screening (A.6.1), managed and encrypted laptops (A.6.7) and office entry controls (A.7.2) are conformant, and 70% of infrastructure is already defined as code.

Top three priorities (next 90 days)

#	Priority	Key actions	Controls	Risks
1	Lock down privileged access and authentication	Just-in-time SSO admin roles, root locked with hardware MFA, individual database credentials, MFA on the Ops Console and vendor accounts.	A.8.2, A.8.5	R01, R02
2	Build basic detection and incident response	Enable GuardDuty and 10–15 priority alerts, keep logs for one year, approve an incident response plan with a CERT-In/DPDP/RBI notification matrix and run a tabletop exercise.	A.8.16, A.5.24	R04
3	Establish governance and close exploitable application gaps	Approve the security policy and appoint an Information Security Manager; close open High VAPT findings, rotate exposed secrets and set remediation SLAs.	A.5.1, A.8.8, A.8.28	R03

If these priorities and the 3–6 month actions are delivered, we estimate average maturity rises from 1.7 to about 3.0, every risk in the register falls to Medium or below, and SecurePay can approach a certification Stage 1 audit in about 12 months.

Results at a glance

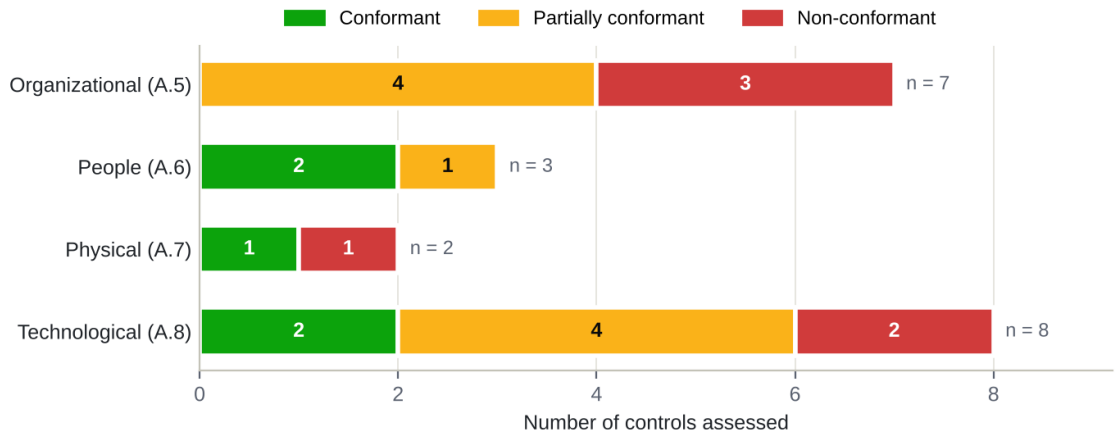


Exhibit - Conformance status of the 20 assessed controls by Annex A theme (detail in section 4)

2. Scope, objectives and methodology

2.1 Objectives

- Determine SecurePay's current conformance with a risk-relevant sample of ISO/IEC 27001:2022 Annex A controls and the ISMS requirements of Clauses 4–10.
- Identify, rate and prioritise the information security risks that come from the gaps found.
- Produce a Statement of Applicability covering all 93 Annex A controls as a basis for the future ISMS.
- Recommend a practical, prioritised remediation roadmap with owners and effort estimates.

2.2 Scope

Dimension	In scope
Organisation	SecurePay Technologies Pvt. Ltd. (all 50 employees) and the outsourced customer support vendor where it handles SecurePay data.
Locations	Bengaluru office (single floor, managed building); remote and hybrid working; AWS ap-south-1 (Mumbai) and ap-south-2 (Hyderabad).
Systems	Payment API, hosted checkout, merchant dashboard, internal Ops Console, AWS production and non-production accounts, GitHub and CI/CD, Google Workspace, SaaS helpdesk, endpoints.
Annex A controls	20 of 93 controls across the four themes (Organizational 7, People 3, Physical 2, Technological 8), including 5 of the 11 controls new in 2022: A.5.7, A.5.23, A.8.9, A.8.16, A.8.28.
Clauses	High-level review of Clauses 4–10 (status and principal gap).
Out of scope	Technical testing (VAPT, configuration review), physical inspection of AWS data centres (inherited controls), PCI DSS and DPDP compliance opinions.

Controls were selected for their relevance to a cloud-hosted payment business: governance foundations (policy, inventory), the third-party and cloud dependencies SecurePay relies on, the regulatory drivers (privacy, incident reporting) and the technical controls that most directly protect payment and personal data (identity, vulnerabilities, configuration, monitoring, cryptography, backup and secure coding).

2.3 Assessment approach

Phase	Activities	Output
1. Plan and scope	Agree objectives, scope and control sample; define rating scales and risk appetite.	Scope statement, rating scales
2. Understand context	Build the organisation profile: business model, assets, systems, data flows, regulatory obligations and stakeholders.	Organisation profile
3. Assess controls	For each control, compare the paraphrased requirement with the (assumed) current state, list the evidence an assessor would request, rate conformance and maturity and record the gap.	Detailed findings (section 6)
4. Assess risk	Identify asset-threat-vulnerability scenarios from the gaps, score likelihood and impact, choose a treatment and estimate target risk.	Risk register, heat maps
5. Report and plan	Draft the SoA, prioritise recommendations into a 12-month roadmap with owners and effort, and present results.	This report, SoA, roadmap

2.4 Rating scales

Each control receives a conformance status, a maturity score (current and 12-month target) and a risk rating for the gap. Full definitions are in Appendix A.

Status	Meaning
Conformant	Control is designed and operating as required; at most minor observations.
Partially conformant	Control exists in part or informally; significant elements are missing, undocumented or inconsistently applied.
Non-conformant	Control is absent or so ineffective that the requirement is not met.

Risk = Likelihood (1–5) × Impact (1–5), giving a score of 1–25. Bands: Low 1–5, Medium 6–10, High 12–16, Critical 20–25. Assumed risk appetite: SecurePay has a low appetite for risks to payment and personal data and to regulatory standing. Risks scored 12 or more (High and Critical) must be treated; Medium risks may be accepted with documented CEO sign-off; Low risks are accepted and monitored. Treatment options are mitigate, transfer, avoid or accept.

2.5 Limitations

- This is a self-directed assessment of a fictional organisation. The current state is assumed, not observed; no interviews, walkthroughs, evidence sampling or technical testing were performed.
- Twenty of 93 controls were assessed in detail. SoA statuses for the other controls are indicative only and should be validated before an ISMS is formalised.
- Findings reflect a point in time (October 2026); conditions may change.
- Regulatory references are summarised for context and are not legal advice.

3. Organisation overview

The full profile is in org-profile.md in the project repository. This section summarises the points that shape the assessment.

Attribute	Detail
Business	Online Payment Aggregator (RBI in-principle authorisation). Hosted checkout, payment links, UPI and card acceptance, and T+1 settlement for about 1,200 SME merchants.
Scale	About 0.9 million transactions and INR 180 crore gross transaction value a month; Series A funded; founded 2021.
People	50 employees: Engineering 20, Operations & Risk 10, Sales & Partnerships 6, Product & Design 5, Leadership 4, Finance/Legal/Compliance 3, HR & Admin 2. Plus 12 outsourced support agents.
Technology	AWS (ECS Fargate, RDS PostgreSQL Multi-AZ, S3, KMS, WAF) in Mumbai, backups in Hyderabad; Node.js and React; GitHub and GitHub Actions; Terraform; Google Workspace; Slack; SaaS helpdesk.
Security posture	No formal ISMS or dedicated security role; the CTO is the de facto security owner. Annual VAPT by a CERT-In empanelled auditor; PCI DSS QSA pre-assessment completed.

3.1 Key information assets

Asset	Description	Classification
Transaction data	Payment records, card tokens, last-4 digits, UPI IDs, amounts, merchant IDs	Restricted
Merchant KYC data	PAN, GST, bank account proof, masked Aadhaar, director details (S3)	Restricted
Customer personal data	Payer names, phone numbers, email addresses (checkout and support)	Confidential
Settlement and payout data	Daily settlement files, merchant bank accounts, payout instructions	Restricted
Source code and secrets	Payment platform code, Terraform, API keys for banks and partners	Restricted
Security and audit logs	CloudTrail, application and load balancer logs	Confidential
Corporate information	Contracts, board papers, HR records, financials	Confidential

3.2 Principal data flows

Flow	Path	Key protection
Card checkout	Payer browser -> hosted checkout -> partner processor hosted fields (PCI L1) -> token -> Payment API -> acquiring bank -> card network	TLS 1.2+, tokenisation, no PAN storage
UPI payment	Payer app -> sponsor bank PSP -> NPCI -> Payment API callback	Signed callbacks, TLS
Merchant onboarding	Merchant uploads KYC -> S3 -> KYC verification API -> Ops review in Ops Console	KMS encryption, Aadhaar masking
Settlement	Acquiring bank settlement file (SFTP) -> reconciliation -> payout via bank API	SFTP, single approver (gap)
Customer support	Customer/merchant -> SaaS helpdesk -> SupportCo agents -> support console	Shared logins, no MFA (gap)
Software delivery	GitHub -> GitHub Actions -> Amazon ECR -> ECS production	Peer review, separate accounts

3.3 Regulatory and contractual obligations

Obligation	Relevance to SecurePay
Digital Personal Data Protection Act, 2023 and DPDP Rules, 2025	SecurePay is a Data Fiduciary: reasonable security safeguards, breach intimation, retention limits, Data Principal rights; penalties up to INR 250 crore per breach of safeguards.
RBI Guidelines on Regulation of Payment Aggregators and Payment Gateways (2020, as amended)	Authorisation conditions, baseline technology and security recommendations, no storage of card data, incident reporting.
RBI directive on storage of payment system data (2018)	Payment data must be stored only in India.

Obligation	Relevance to SecurePay
CERT-In Directions under section 70B of the IT Act (April 2022)	Report specified incidents within 6 hours; keep ICT logs for 180 days in India; synchronise clocks.
PCI DSS v4.0.1	Service provider handling card data in transit; card network and acquirer requirement.
Information Technology Act, 2000	Section 43A liability and offences relating to computer systems.
Partner bank and merchant contracts	Security questionnaires, audit rights, breach notification clauses.

3.4 Stakeholders and interested parties

Internal: CEO (accountable executive), CTO (interim security owner), CFO, Head of Legal & Compliance, Head of Customer Operations, Engineering Lead, Cloud & DevOps Lead, HR & Admin Manager and all staff. External: RBI, CERT-In, Data Protection Board of India, acquiring and sponsor banks, card networks (via acquirer), NPCI (via sponsor bank), merchants, payers (Data Principals), investors, SupportCo, AWS and other suppliers, the PCI QSA and VAPT auditors.

4. Maturity overview

The table and charts below summarise conformance status and maturity by Annex A theme.

Theme	Assessed	Conformant	Partially conformant	Non-conformant	Avg maturity
Organizational (A.5)	7	0 (0%)	4 (57%)	3 (43%)	1.1
People (A.6)	3	2 (67%)	1 (33%)	0 (0%)	2.3
Physical (A.7)	2	1 (50%)	0 (0%)	1 (50%)	1.5
Technological (A.8)	8	2 (25%)	4 (50%)	2 (25%)	2.0
Total	20	5 (25%)	9 (45%)	6 (30%)	1.7

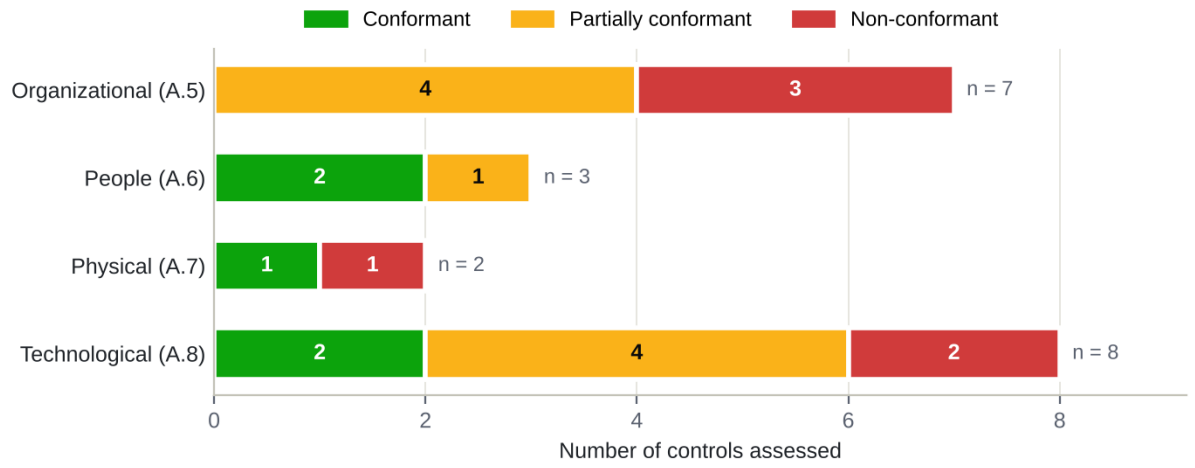


Figure 1 - Conformance status by Annex A theme (number of controls assessed)

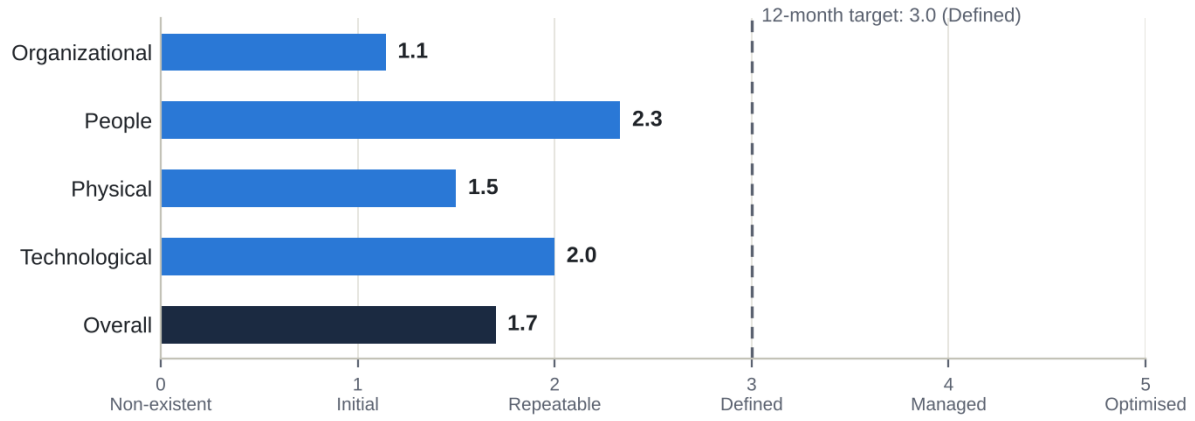


Figure 2 - Average control maturity by theme against the 12-month target

Observations

- **Organizational controls are weakest** (average maturity 1.1). None is fully conformant: governance, supplier management, incident preparation, threat intelligence and privacy all need structure.
- **Technological controls are mixed.** Cloud-native choices give strong encryption and backup, but identity, vulnerability management and monitoring lag behind the risk of a payment platform.
- **People controls are relatively strong** thanks to standard Indian HR practice (background verification) and a managed laptop fleet; awareness training is the gap.
- **Physical exposure is limited** because SecurePay runs no data centre, but laptop re-use and disposal is uncontrolled.
- **The 2022 controls are a blind spot:** of the 5 new controls assessed, 0 are conformant and 2 are non-conformant.

5. Clauses 4–10 summary

Clauses 4–10 set out the management system an organisation must run to be certified, separate from the Annex A controls. SecurePay has no formal ISMS, so most clause requirements are partially met at best. The table gives one line per clause.

Clause	Status	Current state	Principal gap
4. Context of the organization	**Partially conformant**	Leadership understands the business, regulatory and customer context informally.	No documented ISMS scope, internal/external issues or register of interested parties and their requirements.
5. Leadership	**Partially conformant**	CEO is supportive and the CTO acts as informal security owner.	No approved information security policy, no formally assigned ISMS roles or authorities, and no Information Security Manager.
6. Planning	**Non-conformant**	This gap assessment is the first structured look at security risk.	No risk assessment methodology, risk treatment plan, Statement of Applicability or measurable security objectives.
7. Support	**Partially conformant**	Budget and engineering time are available for security tasks on request.	Competence requirements and awareness are not defined, and there is no control of documented information (versioning, approval, retention).
8. Operation	**Partially conformant**	Several operational controls run because partner banks and PCI DSS require them.	Controls are not planned or operated through a risk treatment plan, and risk assessments are not repeated at planned intervals or after major change.
9. Performance evaluation	**Non-conformant**	Only uptime and payment-success metrics are tracked.	No security metrics, no internal audit programme and no management review of the ISMS.
10. Improvement	**Non-conformant**	Problems are fixed when noticed, without root-cause analysis.	No nonconformity and corrective action process or log, and no evidence of continual improvement.

Summary: 0 conformant, 4 partially conformant, 3 non-conformant. The missing risk assessment and treatment process (Clause 6) and the absence of internal audit and management review (Clause 9) would each be major nonconformities at a certification audit. This report's risk register and SoA are a first step towards Clause 6.

6. Detailed Annex A findings

Summary of the 20 controls assessed. Controls marked * are new in ISO/IEC 27001:2022.

Control	Name	Theme	Status	Risk
A.5.1	Policies for information security	Organizational	Partially conformant	Medium
A.5.7*	Threat intelligence	Organizational	Non-conformant	Medium
A.5.9	Inventory of information and other associated assets	Organizational	Partially conformant	Medium
A.5.19	Information security in supplier relationships	Organizational	Non-conformant	High
A.5.23*	Information security for use of cloud services	Organizational	Partially conformant	Medium
A.5.24	Information security incident management planning and preparation	Organizational	Non-conformant	High
A.5.34	Privacy and protection of PII	Organizational	Partially conformant	High
A.6.1	Screening	People	Conformant	Low
A.6.3	Information security awareness, education and training	People	Partially conformant	Medium
A.6.7	Remote working	People	Conformant	Low
A.7.2	Physical entry	Physical	Conformant	Low
A.7.14	Secure disposal or re-use of equipment	Physical	Non-conformant	Medium
A.8.2	Privileged access rights	Technological	Non-conformant	Critical
A.8.5	Secure authentication	Technological	Partially conformant	High
A.8.8	Management of technical vulnerabilities	Technological	Partially conformant	High
A.8.9*	Configuration management	Technological	Partially conformant	Medium
A.8.13	Information backup	Technological	Conformant	Low
A.8.16*	Monitoring activities	Technological	Non-conformant	High
A.8.24	Use of cryptography	Technological	Conformant	Low
A.8.28*	Secure coding	Technological	Partially conformant	High

6.1 Organizational controls (A.5)

A.5.1 Policies for information security

THEME	STATUS	GAP RISK	MATURITY (CURRENT / TARGET)	OWNER / TIMELINE
Organizational	**Partially conformant**	**Medium**	**1 / 3**	CEO (approval); Information Security Manager (drafting) | 0–3 months

Requirement (paraphrased)	Management should set out the organisation's overall direction for information security in an approved, top-level policy, supported by topic-specific policies. These should be communicated to staff and relevant third parties, acknowledged, and reviewed at planned intervals or when significant changes occur.
Current state (assumed)	A six-page 'IT Security Policy' was drafted by the CTO in 2024 to answer a partner bank's due-diligence questionnaire. It has not been approved by the CEO or the Board, carries no version control, owner or review date, and sits in the CTO's personal Google Drive. Employees are not asked to read or acknowledge it. No topic-specific policies exist (access control, acceptable use, cryptography, supplier security, incident management, data retention); some rules are described informally on the engineering wiki.
Evidence requested	Approved Information Security Policy with version history and management sign-off; index of topic-specific policies; policy communication and acknowledgement records (HRMS export); policy review schedule and minutes of the last review.
Gap	A policy exists in draft only. There is no management approval, no communication or acknowledgement by staff, no review cycle and no topic-specific policies, so staff have no authoritative rules and SecurePay cannot demonstrate management direction to RBI, partner banks or a certification auditor.
Recommendation	Refresh the draft into a concise Information Security Policy aligned to ISO/IEC 27001 and PCI DSS and have it approved by the CEO. Build a policy framework of about eight topic-specific policies (access control, acceptable use, cryptography and key management, supplier security, incident management, logging and monitoring, secure development, data protection and retention). Publish through the HRMS with annual e-acknowledgement and set an annual review date.

A.5.7 Threat intelligence

NEW IN 2022

THEME	STATUS	GAP RISK	MATURITY (CURRENT / TARGET)	OWNER / TIMELINE
Organizational	**Non-conformant**	**Medium**	**0 / 3**	Information Security Manager | 6–12 months

Requirement (paraphrased)	The organisation should collect information about threats that are relevant to it, analyse that information to produce useful intelligence (strategic, tactical and operational), and use it to inform risk decisions and to adjust its security controls.
Current state (assumed)	There is no defined threat intelligence process or owner. Engineers occasionally notice security news on social media or in community Slack groups. Nobody is responsible for monitoring CERT-In advisories, AWS security bulletins or disclosures affecting the technology stack (Node.js, PostgreSQL, React, npm packages). A 2025 CERT-In advisory on phishing campaigns targeting payment companies was not reviewed or acted upon. No threat profile exists for SecurePay as an online payment aggregator.
Evidence requested	Threat intelligence procedure and named owner; list of subscribed sources; log of advisories received, triaged and actioned; periodic threat landscape briefing to management; evidence of intelligence feeding into controls (e.g. WAF rule or detection updates).
Gap	Threat information is not collected, analysed or used. SecurePay relies on chance awareness, so threats that specifically target payment platforms (card-testing and enumeration attacks, credential stuffing against merchant logins, malicious npm packages, BEC targeting settlement teams) are not anticipated in its controls.
Recommendation	Assign threat intelligence ownership to the Information Security Manager. Subscribe to CERT-In advisories, AWS security bulletins, GitHub security advisories and vendor feeds, and join a payments or fintech information-sharing community. Hold a fortnightly 30-minute triage with a simple log of advisories and actions taken. Produce a one-page quarterly threat briefing for leadership. Once monitoring is in place, feed indicators of compromise into AWS WAF and GuardDuty threat lists.

A.5.9 Inventory of information and other associated assets

THEME	STATUS	GAP RISK	MATURITY (CURRENT / TARGET)	OWNER / TIMELINE
Organizational	**Partially conformant**	**Medium**	**2 / 3**	Information Security Manager with asset owners | 3–6 months

Requirement (paraphrased)	The organisation should identify its information and the assets associated with it (hardware, software, cloud services, data stores, people-held knowledge), record them in an inventory that is kept up to date, and assign each an owner responsible for its protection.
Current state (assumed)	About 80% of AWS resources carry 'env' and 'service' tags, and HR and Admin keep a laptop register in a spreadsheet (serial number and assigned user). However, there is no inventory of information assets (merchant KYC files, transaction data, settlement files, customer support records). SaaS applications are not catalogued; an informal count during the assessment found about 25. Owners and classification are not assigned, and the laptop register was last updated four months ago.
Evidence requested	Asset register(s) showing owner, classification and location; AWS Config or resource inventory export; SaaS discovery report (e.g. from Google Workspace OAuth app list); reconciliation of the laptop register to the MDM; records of periodic asset reviews.
Gap	The inventory covers only part of the cloud infrastructure and endpoints. It omits information assets and SaaS, lacks owners and classification, and is not kept current. This weakens risk assessment, access reviews and the data mapping SecurePay needs for the DPDP Act.
Recommendation	Create a single asset register (spreadsheet or lightweight GRC tool) that covers information assets, applications and SaaS, cloud services and endpoints. Give every entry an owner and a classification (Public, Internal, Confidential, Restricted). Enforce mandatory AWS tags through AWS Organizations tag policies, reconcile the register monthly against AWS Config and the MDM, and have owners review it quarterly.

A.5.19 Information security in supplier relationships

THEME	STATUS	GAP RISK	MATURITY (CURRENT / TARGET)	OWNER / TIMELINE
Organizational	**Non-conformant**	**High**	**1 / 3**	Head of Customer Operations; Head of Legal & Compliance | 3–6 months

Requirement (paraphrased)	The organisation should define and apply processes to manage the security risks that come from using suppliers' products and services. This includes assessing suppliers before engaging them and agreeing how they may access and handle the organisation's information.
Current state (assumed)	Customer support is outsourced to a Pune-based BPO ('SupportCo', 12 agents). Agents work in a SaaS helpdesk and a read-only internal support console that shows customer names, phone numbers, email addresses, masked card numbers (last four digits), UPI IDs and transaction history. The vendor was selected on cost and no security due diligence was done. The master services agreement has a generic confidentiality clause but no security requirements, breach notification, audit rights or data return and deletion obligations. Agents share three logins to the support console. There is no supplier inventory or risk tiering for the roughly 25 SaaS and service providers in use.
Evidence requested	Supplier security policy; supplier inventory with risk tiering; due-diligence questionnaires and assurance reports (ISO 27001 certificate, SOC 2 report) for critical suppliers; contracts and data processing agreements with security schedules; list of supplier user accounts and access review records.
Gap	There is no supplier security risk management. The highest-risk supplier has broad access to customer personal data through shared credentials and has no contractual security obligations. Under the DPDP Act, SupportCo is a Data Processor and SecurePay, as Data Fiduciary, remains accountable for any breach it causes.
Recommendation	Publish a supplier security policy and build a supplier inventory with risk tiers (critical, high, medium, low). Assess SupportCo immediately using a security questionnaire and a site or virtual visit. Sign a data processing agreement with a security schedule covering minimum controls, incident notification within 6 hours (to support CERT-In timelines), audit rights, data return and deletion, and approval of sub-processors. Replace shared logins with named accounts protected by MFA, mask contact details agents do not need, and review supplier access quarterly.

A.5.23 Information security for use of cloud services

NEW IN 2022

THEME	STATUS	GAP RISK	MATURITY (CURRENT / TARGET)	OWNER / TIMELINE
Organizational	**Partially conformant**	**Medium**	**2 / 3**	CTO; Cloud & DevOps Lead | 3–6 months

Requirement (paraphrased)	The organisation should set up processes for acquiring, using, managing and exiting cloud services that match its security requirements, including a clear split of security responsibilities between the cloud provider and the organisation.
Current state (assumed)	Production runs in AWS ap-south-1 (Mumbai) to meet RBI payment data localisation, using managed services (ECS Fargate, RDS PostgreSQL Multi-AZ, S3, KMS). Good practices are in place: S3 Block Public Access at account level, default encryption at rest, and AWS Organizations with separate production and non-production accounts. However, there is no cloud security policy or documented shared-responsibility matrix, AWS Security Hub and CIS benchmark checks are not enabled, teams adopt SaaS tools without security review, and there is no exit or portability plan.
Evidence requested	Cloud security policy or standard; shared-responsibility matrix per service; evidence of reviewing AWS assurance reports (PCI DSS AOC, SOC 2) via AWS Artifact; cloud security posture findings (Security Hub); SaaS approval records; cloud exit strategy.
Gap	The technical foundations are sound, but cloud use is not governed. There is no policy, no responsibility matrix, no continuous posture assessment, uncontrolled SaaS adoption and no exit strategy.
Recommendation	Approve a cloud security standard and document the shared-responsibility split for each AWS service and critical SaaS application. Enable AWS Security Hub with the CIS AWS Foundations and PCI DSS standards across all accounts. Download and review AWS's PCI DSS AOC and SOC 2 report every year. Introduce a lightweight SaaS approval workflow with a security and privacy checklist, and document a cloud exit and portability plan that can be shown to regulators.

A.5.24 Information security incident management planning and preparation

THEME	STATUS	GAP RISK	MATURITY (CURRENT / TARGET)	OWNER / TIMELINE
Organizational	**Non-conformant**	**High**	**1 / 3**	CTO (interim Information Security Manager) | 0–3 months

Requirement (paraphrased)	The organisation should prepare to handle security incidents by defining, documenting and communicating its incident management processes, roles and responsibilities, so that incidents are dealt with quickly, effectively and consistently.
Current state (assumed)	No incident response plan exists. Incidents are handled ad hoc in a Slack channel by whichever engineer notices. In March 2026 a credential-stuffing attack on merchant dashboard logins was handled over two days without severity classification, a root-cause record, or a decision on whether CERT-In (6-hour) reporting or notification to the acquiring bank was required. Staff do not know how or to whom to report a suspected incident, and there is no contact list for CERT-In, RBI, the acquiring bank or legal counsel.
Evidence requested	Incident response plan and procedures; incident response team roles (RACI); severity matrix; regulatory notification matrix (CERT-In, RBI, Data Protection Board, card networks via the acquirer); incident log; tabletop exercise reports; on-call rota.
Gap	There is no defined incident management capability. Regulatory deadlines (CERT-In reporting within 6 hours, DPDP breach intimation to the Data Protection Board and affected Data Principals, RBI reporting) cannot be met reliably, and lessons from incidents are not captured.
Recommendation	Approve an incident response plan covering preparation, detection, triage and severity, containment, eradication, recovery and post-incident review. Name an incident response team with deputies and a 24x7 on-call rota. Build a regulatory notification matrix with ready-to-use templates. Set up one reporting channel (security@ mailbox plus a Slack workflow). Run a tabletop exercise (card-testing attack and ransomware scenarios) within 90 days and every year after that, and consider an incident response retainer.

A.5.34 Privacy and protection of PII

THEME	STATUS	GAP RISK	MATURITY (CURRENT / TARGET)	OWNER / TIMELINE
Organizational	**Partially conformant**	**High**	**1 / 3**	Head of Legal & Compliance | 3–6 months

Requirement (paraphrased)	The organisation should identify and meet the requirements for preserving privacy and protecting personal data that apply to it under law, regulation and contract.
Current state (assumed)	A privacy policy is published on the website and the checkout flow records consent. Card data is never stored (it is tokenised by the partner processor) and Aadhaar numbers are masked during merchant KYC. However, there is no inventory of what personal data is processed and where, and no retention and deletion schedule (KYC documents of off-boarded merchants are kept indefinitely in S3). No DPDP Act gap analysis has been done, there is no process for Data Principal requests (access, correction, erasure, grievance), and nobody is formally accountable for data protection. Production data is periodically copied to the staging environment for debugging.
Evidence requested	Personal data inventory and records of processing; DPDP Act gap assessment; privacy notices and consent records; retention schedule and deletion logs; Data Principal request and grievance log; appointment of a privacy owner and grievance contact; breach notification procedure; data processing agreements with processors.
Gap	Some basic privacy measures exist, but SecurePay cannot demonstrate DPDP Act compliance. There is no data mapping, no retention limits, no rights handling, no breach notification procedure and no accountable owner, and production personal data is used in non-production environments.
Recommendation	Carry out a DPDP Act gap assessment and build a personal data inventory with data flow maps. Define a retention schedule that respects statutory record-keeping minimums (RBI, PMLA) and automate it with S3 lifecycle rules. Implement a Data Principal request and grievance process with SLAs. Make the Head of Legal & Compliance the accountable privacy owner. Prohibit production personal data in non-production environments (use masked or synthetic data) and add DPDP breach notification to the incident response plan.

6.2 People controls (A.6)

A.6.1 Screening

THEME	STATUS	GAP RISK	MATURITY (CURRENT / TARGET)	OWNER / TIMELINE
People	**Conformant**	**Low**	**3 / 3**	HR & Admin Manager | 3–6 months

Requirement (paraphrased)	Background verification checks should be carried out on candidates before they join and, where appropriate, on an ongoing basis. Checks should follow applicable laws and be proportionate to the business need, the sensitivity of the information the person will access and the risks involved.
Current state (assumed)	All employees go through pre-joining background verification by an accredited third-party agency (identity, address, education, previous employment and criminal records database check). Reports are retained in the HR system. Roles with privileged or financial access also get an additional reference check. System access is granted only after verification clears, as recorded in the HR onboarding checklist.
Evidence requested	Screening procedure or HR onboarding checklist; sample of background verification reports for recent joiners (e.g. 10 of the last 15 hires); candidate consent forms; evidence that checks were completed before system access was granted.
Gap	No significant gap. Observation: screening requirements by role are not written down in a formal procedure, and equivalent screening of vendor staff (SupportCo agents) is not required contractually (addressed under A.5.19).
Recommendation	Document a role-based screening standard. Require suppliers whose staff access SecurePay data to confirm equivalent screening. Consider periodic re-screening for privileged and finance roles.

A.6.3 Information security awareness, education and training

THEME	STATUS	GAP RISK	MATURITY (CURRENT / TARGET)	OWNER / TIMELINE
People	**Partially conformant**	**Medium**	**1 / 3**	Information Security Manager; HR & Admin Manager | 3–6 months

Requirement (paraphrased)	Staff and relevant interested parties should receive security awareness, education and training suited to their role, along with regular updates on the organisation's security policies and procedures.
Current state (assumed)	New joiners receive a 20-minute induction slide on password hygiene and phishing. There is no annual refresher, no role-based training for developers (secure coding), finance (payment fraud and business email compromise) or operations (social engineering), and no phishing simulation. Completion is not tracked, and SupportCo agents receive no SecurePay-specific security training.
Evidence requested	Training plan and content; LMS completion records; phishing simulation results; role-based training records for developers and finance; evidence of training for third-party staff.
Gap	Awareness is limited to a one-off induction with no refresher, no role-based content, no measurement and no coverage of vendor staff. People remain a weak link against phishing and BEC, which are among the most common initial attack vectors in financial services.
Recommendation	Launch an annual awareness programme (30-45 minute modules) with tracked completion and a target of at least 95%. Run quarterly phishing simulations and track report rates. Add role-based training: OWASP Top 10 and secure coding for engineers, payment fraud and BEC for finance and operations, and personal data handling for support. Require SupportCo agents to complete the same module, and report metrics to management every quarter.

A.6.7 Remote working

THEME	STATUS	GAP RISK	MATURITY (CURRENT / TARGET)	OWNER / TIMELINE
People	**Conformant**	**Low**	**3 / 3**	HR & Admin Manager (IT) | 3–6 months

Requirement (paraphrased)	When people work remotely, security measures should be in place to protect information that is accessed, processed or stored outside the organisation's premises.
Current state (assumed)	SecurePay works in a hybrid model (three office days a week). All staff use company-issued laptops enrolled in the MDM with enforced full-disk encryption (FileVault or BitLocker), a five-minute screen lock, automatic OS updates and endpoint anti-malware. Corporate applications are reached through Google Workspace SSO with enforced MFA. Remote working rules (public Wi-Fi, screen privacy, no company data on personal devices) are in the employee handbook and acknowledged at joining.
Evidence requested	Remote working policy (handbook section) with acknowledgement records; MDM compliance report showing encryption and screen-lock status; sample device configurations; SSO and MFA enforcement settings.
Gap	No significant gap. Observation: the MDM report showed 3 of 54 laptops with OS updates pending for more than 30 days, and personal mobile phones can access Gmail and Slack without any device management.
Recommendation	Make device compliance (supported OS version, encryption) a condition of SSO access. Apply basic management or app protection policies to mobile devices that access Workspace and Slack. Reconcile the MDM device list with the asset register every month.

6.3 Physical controls (A.7)

A.7.2 Physical entry

THEME	STATUS	GAP RISK	MATURITY (CURRENT / TARGET)	OWNER / TIMELINE
Physical	**Conformant**	**Low**	**3 / 3**	HR & Admin Manager | 3–6 months

Requirement (paraphrased)	Secure areas should be protected by appropriate entry controls and access points so that only authorised people can get in.
Current state (assumed)	SecurePay occupies one floor of a managed office building in Bengaluru. Building security controls entry with a reception desk, visitor registration against photo ID, and RFID access cards. The SecurePay floor has card-controlled doors whose logs the facility provider keeps for 90 days. Apart from a Wi-Fi access point and ISP router in a locked comms cabinet, no servers or network equipment are on site. Access cards are deactivated as part of the leaver checklist.
Evidence requested	Facility access procedure; access card issuance and revocation records reconciled to the HR leavers list; visitor logs; sample of the facility provider's door access logs; CCTV coverage of entry points.
Gap	No significant gap. Observation: visitors are not escorted on the SecurePay floor once they have registered at reception, and active access cards are not reviewed periodically.
Recommendation	Introduce visible visitor badges and an escort rule on the SecurePay floor. Reconcile active access cards with the HR roster every quarter.

A.7.14 Secure disposal or re-use of equipment

THEME	STATUS	GAP RISK	MATURITY (CURRENT / TARGET)	OWNER / TIMELINE
Physical	**Non-conformant**	**Medium**	**0 / 3**	HR & Admin Manager | 0–3 months

Requirement (paraphrased)	Before equipment containing storage media is disposed of or re-used, the organisation should check that any sensitive data and licensed software have been removed or securely overwritten.
Current state (assumed)	Laptops returned by leavers are reissued to new joiners after the previous user's profile is deleted manually; there is no secure wipe or OS reinstallation. Six old laptops were sold to an informal buyer in 2025 with no data sanitisation and no certificate. There is no disposal procedure or disposal log. Disks are encrypted, but recovery keys are not rotated when a laptop is reassigned.
Evidence requested	Equipment disposal and re-use procedure; disposal log recording the sanitisation method; certificates of data destruction from an authorised e-waste recycler; MDM wipe records.
Gap	There is no controlled process for re-use or disposal. Residual data (source code, credentials, customer data exports) could be recovered by the next user or by a third-party buyer, and selling to informal buyers may also breach the E-Waste (Management) Rules, 2022.
Recommendation	Adopt a procedure that requires an MDM-initiated wipe or factory reset (cryptographic erase) before any laptop is reissued. Dispose of equipment only through an authorised e-waste recycler that provides certificates of data destruction, and keep a disposal log linked to the asset register.

6.4 Technological controls (A.8)

A.8.2 Privileged access rights

THEME	STATUS	GAP RISK	MATURITY (CURRENT / TARGET)	OWNER / TIMELINE
Technological	**Non-conformant**	**Critical**	**1 / 3**	CTO | 0–3 months

Requirement (paraphrased)	The allocation and use of privileged access rights should be restricted and managed so that only authorised people hold them, only for as long as needed, and their use is controlled and monitored.
Current state (assumed)	Five engineers, two of whom have since moved to non-infrastructure roles, permanently hold the AWS 'AdministratorAccess' policy through IAM users. The production account's root user is used occasionally for billing tasks; its credentials sit in a password manager vault shared by three people. Production PostgreSQL is accessed with a shared 'postgres' superuser credential known to seven engineers. No privileged access review has ever been carried out, and privileged activity is not monitored.
Evidence requested	Privileged access management procedure; list of privileged accounts across AWS, databases, GitHub organisation owners and Google Workspace super admins; approval records; privileged access review records; root account usage logs (CloudTrail); break-glass procedure.
Gap	Privileged access to the production cloud and database is excessive, permanent and shared, with no approval, review or monitoring. A single compromised engineer laptop or credential would give an attacker full control of the payment platform and customer data.
Recommendation	Move to AWS IAM Identity Center (SSO) with MFA, role-based permission sets and time-bound (just-in-time) elevation for administrative roles, and remove IAM users with admin rights. Lock away the root user (hardware MFA kept in a safe, alerting on any root login, documented break-glass procedure). Replace the shared database superuser with individual IAM-authenticated roles and session logging. Review privileged access monthly for six months, then quarterly, and limit GitHub organisation owners and Workspace super admins to two people each.

A.8.5 Secure authentication

THEME	STATUS	GAP RISK	MATURITY (CURRENT / TARGET)	OWNER / TIMELINE
Technological	**Partially conformant**	**High**	**2 / 3**	Engineering Lead | 0–3 months

Requirement (paraphrased)	Secure authentication technologies and procedures should be in place, matched to how sensitive the information is and how access is restricted, for example multi-factor authentication for higher-risk access.
Current state (assumed)	Google Workspace SSO with enforced 2-step verification covers email and most internal SaaS, and AWS IAM users have MFA. However, the internal 'Ops Console' (used by operations and support to view merchant and customer data and to initiate refunds) uses username and password only, with no account lockout. SupportCo agents use shared credentials without MFA. The merchant dashboard offers optional OTP 2FA, used by about 18% of merchants; this was the target of the March 2026 credential-stuffing attack. The merchant password policy requires only 8 characters and does not check for breached passwords.
Evidence requested	Authentication standard; SSO and MFA enforcement reports (Workspace, AWS); authentication configuration of the Ops Console and merchant dashboard (MFA, lockout, rate limiting); results of login rate-limit testing; list of accounts without MFA.
Gap	Corporate identities are well protected, but the internal and customer-facing applications that expose personal data and can move money (refunds) lack MFA, account lockout and brute-force protection.
Recommendation	Put the Ops Console behind Google Workspace SSO with enforced MFA and give vendor agents named accounts. Make 2FA mandatory for merchant users with refund or payout permissions and strongly encourage it for everyone else. Add rate limiting, progressive lockout and bot protection (AWS WAF rate-based rules, CAPTCHA) to login endpoints, and check new passwords against breached-password lists. Consider phishing-resistant MFA (FIDO2 security keys) for administrators.

A.8.8 Management of technical vulnerabilities

THEME	STATUS	GAP RISK	MATURITY (CURRENT / TARGET)	OWNER / TIMELINE
Technological	**Partially conformant**	**High**	**2 / 3**	Engineering Lead | 0–3 months

Requirement (paraphrased)	The organisation should get timely information about technical vulnerabilities in the systems it uses, assess how exposed it is, and take suitable action (patching or other mitigation) within defined timeframes.
Current state (assumed)	GitHub Dependabot alerts are enabled on all repositories and container base images are rebuilt monthly. An annual VAPT is performed by a CERT-In empanelled auditor (last in January 2026) because partner banks require it. However, 4 of the 11 High findings from that VAPT are still open nine months later, including an insecure direct object reference (IDOR) in the merchant reports API and missing rate limiting on the OTP verification endpoint. There are 142 open Dependabot alerts (17 Critical or High). No remediation SLAs exist, containers and cloud workloads are not scanned, vulnerability metrics are not tracked, and the quarterly external ASV scans required by PCI DSS have not started.
Evidence requested	Vulnerability management procedure with SLAs; VAPT reports and remediation tracker; Dependabot and SCA dashboards; container image scan results (Amazon ECR or Inspector); ASV scan reports; risk acceptance records for exceptions.
Gap	Vulnerabilities are found but not fixed in a timely or tracked way. There are no SLAs, owners or exception process, and container, cloud and ASV scanning are missing.
Recommendation	Define remediation SLAs by severity (e.g. Critical 7 days, High 30 days, Medium 90 days) with documented risk acceptance for exceptions. Close the four open High VAPT findings within 30 days and get them retested. Enable Amazon ECR enhanced scanning (Amazon Inspector) and run it in CI. Work through the Dependabot backlog in a weekly triage. Start quarterly ASV scans, move to twice-yearly VAPT plus retests after major releases, and report vulnerability ageing to management every month.

A.8.9 Configuration management

NEW IN 2022

THEME	STATUS	GAP RISK	MATURITY (CURRENT / TARGET)	OWNER / TIMELINE
Technological	**Partially conformant**	**Medium**	**2 / 3**	Cloud & DevOps Lead | 6–12 months

Requirement (paraphrased)	Security configurations, including baselines, for hardware, software, services and networks should be defined, documented, implemented, monitored and reviewed.
Current state (assumed)	About 70% of AWS infrastructure is defined in Terraform and changes are peer-reviewed through pull requests. The rest (a legacy EC2 bastion host, some security groups and the AWS WAF rules) was created by hand in the console. No hardening baselines are documented (e.g. CIS Benchmarks for AWS, PostgreSQL or container images), there is no drift detection, and AWS Config is enabled only in the production account with no rules.
Evidence requested	Configuration management standard and hardening baselines; Terraform repository and pull request history; AWS Config rules or conformance pack results; drift detection reports; configuration exception register.
Gap	Infrastructure-as-code adoption is good but incomplete. Without defined secure baselines, drift detection or compliance monitoring, misconfigurations, a leading cause of cloud breaches, may go unnoticed.
Recommendation	Adopt CIS AWS Foundations and the relevant CIS Docker and PostgreSQL benchmarks as baselines. Import the remaining hand-built resources into Terraform and add policy-as-code checks (e.g. Checkov or tfsec) to the CI pipeline. Enable AWS Config conformance packs in all accounts with alerts on drift. Retire the legacy bastion host in favour of AWS Systems Manager Session Manager.

A.8.13 Information backup

THEME	STATUS	GAP RISK	MATURITY (CURRENT / TARGET)	OWNER / TIMELINE
Technological	**Conformant**	**Low**	**3 / 3**	Cloud & DevOps Lead | 3–6 months

Requirement (paraphrased)	Backup copies of information, software and systems should be kept and tested regularly in line with an agreed backup policy.
Current state (assumed)	Amazon RDS automated backups are enabled with 35-day retention and point-in-time recovery. Daily snapshots are copied to ap-south-2 (Hyderabad) and encrypted with a separate KMS key. S3 buckets holding KYC documents and settlement files have versioning and cross-region replication, and infrastructure can be rebuilt from Terraform. A documented backup standard sets RPO at 15 minutes and RTO at 4 hours. A restore of the production database into an isolated account was tested and documented in June 2026 (completed in 2 hours 40 minutes).
Evidence requested	Backup policy with RPO and RTO; AWS Backup or RDS configuration evidence; cross-region copy evidence; restore test reports; backup failure alerts.
Gap	No significant gap. Observations: restore tests are not scheduled on a recurring basis; GitHub and Google Workspace data rely solely on the providers' own resilience; backups are not immutable (AWS Backup Vault Lock is not enabled), so a compromised administrator or ransomware could delete them.
Recommendation	Schedule quarterly restore tests. Enable AWS Backup Vault Lock in compliance mode for critical backups. Add third-party backup for GitHub and Google Workspace, and alert on failed backup jobs.

A.8.16 Monitoring activities

NEW IN 2022

THEME	STATUS	GAP RISK	MATURITY (CURRENT / TARGET)	OWNER / TIMELINE
Technological	**Non-conformant**	**High**	**1 / 3**	CTO; Cloud & DevOps Lead | 0–3 months

Requirement (paraphrased)	Networks, systems and applications should be monitored for unusual behaviour, and appropriate action should be taken to evaluate possible security incidents.
Current state (assumed)	AWS CloudTrail (management events) is enabled across the organisation, and load balancer and application logs go to CloudWatch Logs with 30-day retention. CloudWatch alarms exist only for availability and performance (CPU, HTTP 5xx rates). Nobody reviews security logs. Amazon GuardDuty and VPC Flow Logs are disabled, and there is no SIEM or alerting on security events such as root logins, IAM policy changes, bulk data exports or unusual refund volumes. The March 2026 credential-stuffing attack was detected through a merchant complaint about 19 hours after it began. Related observation (A.8.15): 30-day log retention falls short of the 180 days required by the CERT-In Directions (April 2022) and the 12 months required by PCI DSS.
Evidence requested	Logging and monitoring standard; inventory of log sources and retention settings; SIEM or alert use-case catalogue; alert triage records; GuardDuty findings history; evidence of regular log review; escalation procedure.
Gap	Logs are collected but not monitored. There is no capability to detect security events in a high-value payment environment, and log retention does not meet CERT-In or PCI DSS requirements.
Recommendation	Enable GuardDuty, VPC Flow Logs, S3 data events for sensitive buckets and Security Hub now. Keep logs for at least one year (with 180 days readily available in India) in a dedicated, write-protected log archive account. Implement an initial set of 10-15 high-priority alerts (root or break-glass use, IAM changes, high-severity GuardDuty findings, WAF spikes, login failure spikes, abnormal refund or payout activity) routed to the on-call engineer. Within 6–12 months adopt a SIEM or engage a managed detection and response (MDR) provider for 24x7 coverage.

A.8.24 Use of cryptography

THEME	STATUS	GAP RISK	MATURITY (CURRENT / TARGET)	OWNER / TIMELINE
Technological	**Conformant**	**Low**	**3 / 3**	CTO | 3–6 months

Requirement (paraphrased)	Rules for using cryptography effectively should be defined and applied, including how cryptographic keys are generated, stored, rotated, used and destroyed.
Current state (assumed)	All external endpoints enforce TLS 1.2 or higher with strong cipher suites (SSL Labs grade A) and HSTS. Data at rest in RDS, S3 and EBS is encrypted with AWS KMS customer-managed keys that rotate automatically every year, and key policies limit use to service roles. Card data is never stored: the card number is captured in the partner processor's hosted fields and replaced by a token. Webhooks to merchants are signed with HMAC-SHA256, and partner bank API credentials are kept in AWS Secrets Manager.
Evidence requested	Cryptography and key management policy; TLS scan results; KMS key inventory, rotation settings and key policies; encryption-at-rest configuration; tokenisation architecture and the partner processor's PCI DSS AOC; review of the webhook signing implementation.
Gap	No significant technical gap. Observation: these practices are not written down in a cryptography and key management policy, and certificates outside AWS Certificate Manager are not inventoried or monitored for expiry.
Recommendation	Document a cryptography and key management policy (approved algorithms and key lengths, rotation, ownership, crypto-periods). Keep an inventory of certificates and keys with expiry alerts, and review crypto-agility (including post-quantum readiness) during the annual policy review.

A.8.28 Secure coding NEW IN 2022

THEME	STATUS	GAP RISK	MATURITY (CURRENT / TARGET)	OWNER / TIMELINE
Technological	**Partially conformant**	**High**	**2 / 3**	Engineering Lead | 0–3 months

Requirement (paraphrased)	Secure coding principles should be applied throughout software development so that code is written in a way that reduces the chance of security vulnerabilities.
Current state (assumed)	GitHub branch protection requires one peer review before merging to main, and unit tests run in GitHub Actions. Developers use an ORM that prevents most SQL injection. However, there is no secure coding standard or checklist, reviews focus on functionality, and no SAST or secret-scanning tools are used. A scan of repository history during the assessment found nine hard-coded secrets, including a still-valid SMS gateway API key and a staging database password. Developers have had no secure coding training, and the IDOR found in the VAPT points to missing authorisation checks in the code.
Evidence requested	Secure coding standard (e.g. based on OWASP ASVS and Top 10); code review checklist; SAST, SCA and secret-scanning configuration and results; sample pull requests showing security review; developer training records; threat models for critical features.
Gap	Secure coding depends on individual developers' knowledge. There is no standard, no automated security testing and no training, as shown by hard-coded secrets and authorisation flaws (IDOR) in the payment platform code.
Recommendation	Rotate all exposed secrets immediately and move them to AWS Secrets Manager, then enable GitHub secret scanning with push protection. Adopt a secure coding standard based on OWASP ASVS Level 2 with a pull request security checklist (authorisation, input validation, logging, secrets). Add SAST (e.g. Semgrep or CodeQL) and SCA to CI, blocking merges on High findings. Run annual secure coding training, introduce lightweight threat modelling for new payment features, and nominate a security champion in each squad.

7. Risk assessment

Risks were identified as asset-threat-vulnerability scenarios that follow from the control gaps. Each was scored for likelihood and impact (scales in Appendix A) before treatment, a treatment option was chosen in line with the assumed risk appetite, and a target score was estimated assuming the treatment plan is delivered.



Figure 3 - Risk heat maps: inherent risk (left) and target risk after treatment (right). Cells show the risk score; labels identify risks in the register.

7.1 Risk register summary

ID	Risk	L	I	Score	Rating	Treatment	Owner	Target
R01	Compromise of privileged cloud and database accounts	4	5	20	Critical	Mitigate	CTO	Medium
R02	Customer personal data exposed through the outsourced support vendor	4	4	16	High	Mitigate	Head of Customer Operations	Medium
R03	Exploitation of unpatched vulnerabilities in the payment API and merchant dashboard	4	4	16	High	Mitigate	Engineering Lead	Medium
R04	Undetected intrusion and failure to report within CERT-In's 6-hour window	3	5	15	High	Mitigate	CTO (interim ISM)	Medium
R05	Regulatory penalty for non-compliance with the DPDP Act, 2023	3	5	15	High	Mitigate	Head of Legal & Compliance	Medium
R06	Business email compromise leading to fraudulent settlement payouts	3	4	12	High	Transfer	CFO	Medium
R07	Exposure of production personal data in non-production environments	3	3	9	Medium	Avoid	Engineering Lead	Low
R08	Prolonged outage of the AWS Mumbai region disrupting payment processing	2	4	8	Medium	Accept	CEO	Medium

L = likelihood, I = impact. Target = rating after the treatment plan (scores in section 7.2). Inherent profile: 1 Critical, 5 High, 2 Medium, 0 Low.

7.2 Risk scenarios and treatment plans

R01 Compromise of privileged cloud and database accounts	Critical	4 x 5 = 20
Asset	AWS production environment; transaction and customer databases	
Threat	External attacker using stolen credentials (phishing, malware on an engineer laptop) or a malicious insider	
Vulnerability	Standing AWS admin rights for five engineers, shared root and database superuser credentials, no privileged access review or monitoring	
Related controls	A.8.2; A.8.5; A.8.16	
Treatment	Mitigate: Move to SSO-based just-in-time admin roles, lock away root with hardware MFA, replace the shared DB superuser with individual IAM-authenticated roles, alert on privileged activity	
Owner / target	CTO. Target L2 x I5 = 10 (Medium)	

R02 Customer personal data exposed through the outsourced support vendor	High	4 x 4 = 16
Asset	Customer and merchant personal data in the helpdesk and support console	
Threat	Vendor insider misuse, or compromise of the vendor's environment or shared accounts	
Vulnerability	No supplier due diligence, no security clauses or DPA, shared logins without MFA, full contact details visible to all agents	
Related controls	A.5.19; A.8.5; A.5.34	
Treatment	Mitigate: Supplier security assessment, DPA with security schedule and 6-hour breach notification, named MFA-protected accounts, field masking, quarterly access reviews	
Owner / target	Head of Customer Operations. Target L2 x I4 = 8 (Medium)	

R03 Exploitation of unpatched vulnerabilities in the payment API and merchant dashboard	High	4 x 4 = 16
Asset	Payment API; merchant dashboard; underlying containers and libraries	
Threat	External attacker exploiting known vulnerabilities or OWASP Top 10 weaknesses (e.g. IDOR)	
Vulnerability	Four High VAPT findings open for nine months, 17 Critical/High dependency alerts, no remediation SLAs, no SAST or container scanning	
Related controls	A.8.8; A.8.28; A.8.9	
Treatment	Mitigate: Close open High findings within 30 days, set remediation SLAs, add SAST/SCA and container scanning to CI, quarterly ASV scans and retests	
Owner / target	Engineering Lead. Target L2 x I4 = 8 (Medium)	

R04 Undetected intrusion and failure to report within CERT-In's 6-hour window	High	3 x 5 = 15
Asset	Payment platform and its security logs	
Threat	Persistent attacker, ransomware operator or fraud ring operating unnoticed	
Vulnerability	No security monitoring or alerting, GuardDuty disabled, 30-day log retention, no incident response plan	
Related controls	A.8.16; A.5.24; A.8.15	
Treatment	Mitigate: Enable GuardDuty and priority alerts, extend log retention to one year, approve and exercise an incident response plan with a regulatory notification matrix, then MDR or SIEM	
Owner / target	CTO (interim ISM). Target L2 x I4 = 8 (Medium)	

R05 Regulatory penalty for non-compliance with the DPDP Act, 2023	High	3 x 5 = 15
Asset	Personal data of customers, merchants and employees	
Threat	Enforcement by the Data Protection Board after a breach or complaint	
Vulnerability	No personal data inventory, retention schedule, rights-request process or breach notification procedure; production data used in staging	
Related controls	A.5.34; A.5.9; A.8.10	
Treatment	Mitigate: DPDP gap assessment, data inventory and flow maps, retention schedule with automated deletion, Data Principal request process, privacy owner appointed	
Owner / target	Head of Legal & Compliance. Target L2 x I5 = 10 (Medium)	

R06 Business email compromise leading to fraudulent settlement payouts	High	3 x 4 = 12
Asset	Merchant settlement and payout process; finance mailboxes	
Threat	Social engineering or BEC: an attacker impersonates a merchant or executive to change bank details or approve a payout	
Vulnerability	Induction-only awareness training, no phishing simulation, payout bank-detail changes accepted by email with a single approver	
Related controls	A.6.3; A.5.3; A.5.14	
Treatment	Transfer: Buy cyber insurance with social-engineering fraud cover to transfer residual financial loss; supporting controls: dual approval and call-back verification for bank-detail changes, role-based BEC training	
Owner / target	CFO. Target L2 x I3 = 6 (Medium)	

R07 Exposure of production personal data in non-production environments	Medium	3 x 3 = 9
Asset	Staging and developer environments	
Threat	Accidental leakage or attacker access to the less-protected staging environment	
Vulnerability	Production database copied to staging without masking; staging has broader access and weaker monitoring	
Related controls	A.8.33; A.8.11; A.5.34	
Treatment	Avoid: Stop copying production data to non-production; use synthetic or irreversibly masked datasets generated by a controlled pipeline; purge existing staging copies	
Owner / target	Engineering Lead. Target L1 x I3 = 3 (Low)	

R08 Prolonged outage of the AWS Mumbai region disrupting payment processing	Medium	2 x 4 = 8
Asset	Payment processing platform (single-region deployment)	
Threat	Cloud provider regional outage or large-scale service disruption	
Vulnerability	Single-region, multi-AZ deployment; no tested regional failover (backups are copied to Hyderabad)	
Related controls	A.8.14; A.5.30; A.8.13	
Treatment	Accept: Accept within appetite: Multi-AZ resilience and cross-region backups are in place and active-active multi-region costs are disproportionate at current scale. Document a DR runbook, re-evaluate at 12 months or when monthly volume exceeds 3 million transactions	
Owner / target	CEO. Target L2 x I4 = 8 (Medium)	

8. Statement of Applicability

The SoA records, for every one of the 93 Annex A controls, whether it is applicable, why, and its implementation status. 90 controls are applicable and 3 are excluded with justification. The 20 controls assessed in detail carry their assessed status; the remaining statuses are indicative and must be confirmed when the ISMS is formalised. The full SoA is in Appendix B and in data/soa.csv.

Theme	Controls	Implemented	Partially impl.	Not implemented	Not applicable
Organizational (A.5)	37	1	22	14	0
People (A.6)	8	4	3	1	0
Physical (A.7)	14	8	3	1	2
Technological (A.8)	34	8	19	6	1
Total	93	21	47	22	3

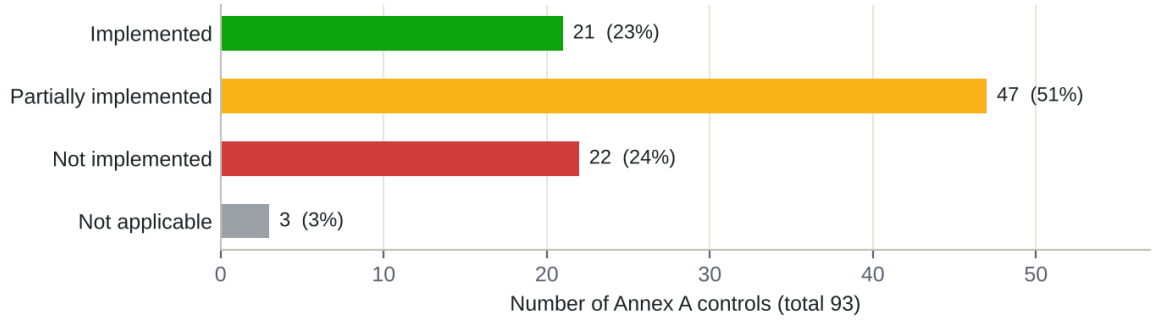


Figure 4 - Implementation status of all 93 Annex A controls

8.1 Exclusions

Control	Name	Justification for exclusion
A.7.6	Working in secure areas	Not applicable: SecurePay operates no secure areas such as server rooms or data centres. Production runs in AWS, whose secure areas are covered by AWS's certified controls.
A.7.12	Cabling security	Not applicable: SecurePay owns no cabling infrastructure. Office cabling is owned and managed by the facility provider and data centre cabling is inherited from AWS.
A.8.30	Outsourced development	Not applicable: all software is developed by in-house employees and no development is outsourced. To be revisited if development is outsourced in future.

Physical data centre controls (for example A.7.1, A.7.5 and A.7.11) remain applicable but are largely inherited from AWS. SecurePay should verify them each year through AWS Artifact (SOC 2 and PCI DSS AOC) rather than exclude them.

9. Prioritised remediation roadmap

Recommendations are sequenced by risk reduction and dependency. Quick wins in the first three months target the Critical and High risks with mostly configuration and governance changes; the next two phases build repeatable processes and then the capabilities needed for certification. Effort is indicative internal person-days.

9.1 Phase 1 - Quick wins (0–3 months)

ID	Initiative	Controls / risks	Effort	Owner	Success measure
Q1	Lock down privileged access: SSO-based just-in-time admin roles, root locked with hardware MFA, individual database credentials	A.8.2; A.8.5 | R01	Medium (10-12 person-days)	CTO	Zero standing AWS admin users; zero shared DB credentials
Q2	Enforce MFA and lockout on the Ops Console, support tools and privileged merchant users; replace vendor shared logins	A.8.5; A.5.19 | R01; R02	Medium (8 person-days)	Engineering Lead	100% of internal and vendor users on SSO with MFA
Q3	Enable GuardDuty, VPC Flow Logs and Security Hub; extend log retention to 1 year; deploy 10-15 priority alerts with on-call routing	A.8.16; A.8.15 | R04	Medium (10 person-days)	Cloud & DevOps Lead	Priority alerts live; retention >= 365 days
Q4	Approve incident response plan with CERT-In / DPDP / RBI notification matrix; run first tabletop exercise	A.5.24 | R04	Medium (8 person-days)	CTO (interim ISM)	Plan approved; tabletop completed within 90 days
Q5	Approve Information Security Policy; appoint Information Security Manager; form a monthly security steering group	A.5.1; Clause 5 | All	Low (4 person-days)	CEO	Policy signed; ISM appointed; steering group minutes
Q6	Close the 4 open High VAPT findings and retest; define vulnerability remediation SLAs	A.8.8 | R03	Medium (12 person-days)	Engineering Lead	0 High findings older than 30 days
Q7	Rotate the 9 exposed secrets; enable GitHub secret scanning with push protection	A.8.28 | R03	Low (3 person-days)	Engineering Lead	All exposed secrets rotated; push protection on all repos
Q8	Stop copying production data to staging and purge existing copies (risk avoidance)	A.8.33; A.5.34 | R07	Low (4 person-days)	Engineering Lead	No production PII in non-production
Q9	Introduce secure wipe before laptop reissue and certified e-waste disposal	A.7.14 | -	Low (2 person-days)	HR & Admin Manager	100% of reissued or disposed devices have wipe records

9.2 Phase 2 - Build core processes (3–6 months)

ID	Initiative	Controls / risks	Effort	Owner	Success measure
M1	Supplier security programme: inventory and tiering, SupportCo assessment, DPA with security schedule, quarterly access review	A.5.19; A.5.20; A.5.22 | R02	Medium (15 person-days)	Head of Customer Operations; Legal	DPA signed; all critical suppliers assessed
M2	DPDP compliance programme: data inventory, flow maps, retention schedule, rights-request and grievance process	A.5.34; A.8.10 | R05	High (30 person-days)	Head of Legal & Compliance	Data inventory complete; retention automated for KYC data
M3	Information asset register with owners and classification; mandatory AWS tag policies	A.5.9; A.5.12 | R05	Medium (10 person-days)	Information Security Manager	100% of assets have an owner and classification
M4	Cloud security standard, shared-responsibility matrix, Security Hub CIS/PCI standards, SaaS approval workflow	A.5.23 | R01; R08	Medium (10 person-days)	CTO	Security Hub score >= 85%
M5	Secure coding standard (OWASP ASVS L2), SAST/SCA in CI, secure coding training, security champions	A.8.28; A.8.25 | R03	Medium (15 person-days)	Engineering Lead	SAST on 100% of repos; 100% of engineers trained
M6	Awareness programme: annual training, quarterly phishing simulations, BEC training for finance; dual approval for payout changes	A.6.3; A.5.3 | R06	Low (6 person-days + tool licence)	Information Security Manager; CFO	Training completion >= 95%; phishing click rate < 5%
M7	Formal risk assessment methodology, risk treatment plan, ISMS scope and approved Statement of Applicability	Clauses 4, 6 | All	Medium (10 person-days)	Information Security Manager	Risk treatment plan and SoA approved by CEO

9.3 Phase 3 - Mature and certify (6–12 months)

ID	Initiative	Controls / risks	Effort	Owner	Success measure
L1	Managed detection and response (MDR) or SIEM with 24x7 coverage	A.8.16 | R04	High (vendor contract + 15 person-days)	CTO	Mean time to detect < 1 hour for priority use cases
L2	Threat intelligence process: sources, fortnightly triage log, quarterly threat briefing	A.5.7; A.5.6 | R03; R04	Low (5 person-days)	Information Security Manager	Advisory log maintained; 4 briefings per year
L3	Complete infrastructure-as-code coverage, CIS baselines, policy-as-code and drift detection; retire legacy bastion	A.8.9 | R01; R03	Medium (15 person-days)	Cloud & DevOps Lead	100% of production resources in Terraform
L4	Business continuity and DR plan with a tested regional recovery runbook	A.5.30; A.8.14 | R08	Medium (12 person-days)	CTO	DR test meets RTO 4 h / RPO 15 min
L5	Internal audit, management review and corrective action process; procure cyber insurance	Clauses 9, 10 | R06	Medium (10 person-days)	CEO; CFO	First internal audit and management review completed
L6	ISO/IEC 27001 certification readiness review ahead of a Stage 1 audit	All | All	High (20 person-days)	CEO; Information Security Manager	Readiness review with no major nonconformities

Dependencies: appoint the Information Security Manager (Q5) first, since that role owns most Phase 2 and 3 items. Supplier (M1) and DPDP (M2) work need Legal capacity in parallel. The MDR/SIEM decision (L1) should build on the alert use cases proven in Q3.

10. Conclusion

SecurePay has the technical building blocks of a secure payment platform: data stays in India, card data is tokenised, encryption and backups are sound, laptops are managed and staff are screened. What it lacks is the management system that makes security deliberate and provable. Policies are unapproved, nobody owns security formally, risks are not assessed, and nothing is monitored, audited or improved systematically.

The most urgent exposures are privileged access to production, the inability to detect and report incidents within regulatory deadlines, and personal data held by an unassessed support vendor. All three can be reduced substantially within 90 days, mainly through configuration and governance work rather than new tools.

We recommend that leadership approve the roadmap in section 9, appoint an Information Security Manager now, and track progress monthly through a security steering group. On that path, SecurePay can expect to reach a 'Defined' maturity level and be ready for an ISO/IEC 27001 Stage 1 audit in about 12 months, while making clear progress on its PCI DSS, DPDP and RBI obligations.

> Reminder: this report concerns a fictional organisation and assumed conditions. It was prepared as a self-directed portfolio exercise and is not the output of a real client engagement.

Appendix A - Rating definitions

A.1 Maturity scale (CMMI-inspired)

Level	Name	Description
0	Non-existent	No recognisable process or control.
1	Initial	Ad hoc and person-dependent; undocumented; results vary.
2	Repeatable	Practised consistently by some teams but not documented, approved or measured.
3	Defined	Documented, approved, communicated and applied consistently across the organisation.
4	Managed	Measured with metrics, monitored and reviewed; deviations are corrected.
5	Optimised	Continuously improved and automated, using metrics and threat intelligence.

A.2 Likelihood scale

Score	Rating	Description
1	Rare	Not expected in the next 3 years; requires exceptional circumstances.
2	Unlikely	Could occur within 3 years; few enabling weaknesses.
3	Possible	Could occur within the next year; known weaknesses exist.
4	Likely	Expected within the next year; weaknesses are known to attackers or have been exploited.
5	Almost certain	Expected within months, or already occurring.

A.3 Impact scale

Score	Rating	Financial	Regulatory / legal	Customers and data	Operations
1	Negligible	< INR 5 lakh	None	No personal data affected	< 15 min disruption
2	Minor	INR 5-25 lakh	Informal query	< 1,000 records	< 1 h outage
3	Moderate	INR 25 lakh-1 crore	Regulatory inquiry or audit observation	1,000-10,000 records	1-4 h outage
4	Major	INR 1-5 crore	Formal regulatory action, penalty, PCI non-compliance	10,000-100,000 records; merchant churn	4-24 h outage
5	Severe	> INR 5 crore	DPDP penalty, RBI suspension of authorisation	> 100,000 records; national media	> 24 h outage

A.4 Risk rating bands and treatment

Score	Rating	Required response
20-25	**Critical**	Immediate treatment; CEO informed within 24 hours; tracked weekly.
12-16	**High**	Treatment plan within 30 days; above appetite; tracked monthly.
6-10	**Medium**	Treat or formally accept with CEO sign-off; reviewed quarterly.
1-5	**Low**	Accept and monitor through normal operations.

Treatment options: Mitigate (reduce likelihood or impact with controls), Transfer (shift financial impact, e.g. insurance or contract), Avoid (stop the activity that creates the risk), Accept (retain the risk with documented approval).

Appendix B - Statement of Applicability (all 93 controls)

* = control new in ISO/IEC 27001:2022. Bold IDs were assessed in detail in section 6. Statuses of other controls are indicative.

Control	Name	Appl.	Justification	Implementation status
A.5.1	Policies for information security	Y	Required to set management direction for the ISMS and expected by RBI, partner banks and PCI DSS.	**Partially implemented**
A.5.2	Information security roles and responsibilities	Y	Security ownership must be assigned across a small team where the CTO currently holds it informally.	**Partially implemented**
A.5.3	Segregation of duties	Y	Conflicting duties exist in code deployment, refunds and settlement payouts.	**Partially implemented**
A.5.4	Management responsibilities	Y	Managers must require staff and contractors to follow security policies.	**Partially implemented**
A.5.5	Contact with authorities	Y	Mandatory reporting to CERT-In, RBI and the Data Protection Board; liaison with law enforcement for fraud.	**Not implemented**
A.5.6	Contact with special interest groups	Y	Fintech and security communities provide early warning of sector threats.	**Not implemented**
A.5.7*	Threat intelligence	Y	Payment platforms are actively targeted; intelligence is needed to adapt controls.	**Not implemented**
A.5.8	Information security in project management	Y	New payment products and integrations must consider security from the start.	**Partially implemented**
A.5.9	Inventory of information and other associated assets	Y	Foundation for risk assessment, access control and DPDP data mapping.	**Partially implemented**
A.5.10	Acceptable use of information and other associated assets	Y	Staff handle personal and payment data and must know the rules of use.	**Partially implemented**
A.5.11	Return of assets	Y	Laptops and access cards must be recovered from leavers.	**Implemented**
A.5.12	Classification of information	Y	Needed to distinguish payment, personal, confidential and public information.	**Not implemented**
A.5.13	Labelling of information	Y	Supports classification of documents and data exports.	**Not implemented**
A.5.14	Information transfer	Y	Settlement files and reports are exchanged with banks, merchants and the support vendor.	**Partially implemented**
A.5.15	Access control	Y	Access to payment and personal data must follow need-to-know rules.	**Partially implemented**
A.5.16	Identity management	Y	Identity lifecycle for employees, vendor agents and service accounts.	**Partially implemented**
A.5.17	Authentication information	Y	Passwords, API keys and secrets must be issued and protected securely.	**Partially implemented**
A.5.18	Access rights	Y	Access must be provisioned, reviewed and revoked in a controlled way.	**Partially implemented**
A.5.19	Information security in supplier relationships	Y	Critical reliance on a support BPO, cloud and SaaS suppliers.	**Not implemented**
A.5.20	Addressing information security within supplier agreements	Y	Supplier contracts must carry security and data protection obligations.	**Not implemented**
A.5.21	Managing information security in the ICT supply chain	Y	Heavy use of open-source packages and SaaS components.	**Partially implemented**
A.5.22	Monitoring, review and change management of supplier services	Y	Supplier performance and security must be monitored over time.	**Not implemented**
A.5.23*	Information security for use of cloud services	Y	The production platform is hosted entirely on AWS.	**Partially implemented**
A.5.24	Information security incident management planning and preparation	Y	Regulatory incident reporting obligations (CERT-In, RBI, DPDP).	**Not implemented**
A.5.25	Assessment and decision on information security events	Y	Events must be triaged consistently to decide if they are incidents.	**Not implemented**
A.5.26	Response to information security incidents	Y	Incidents must be contained and resolved per a documented procedure.	**Partially implemented**
A.5.27	Learning from information security incidents	Y	Lessons from incidents (e.g. March 2026 credential stuffing) must improve controls.	**Not implemented**
A.5.28	Collection of evidence	Y	Evidence may be needed for fraud cases, regulators or litigation.	**Not implemented**
A.5.29	Information security during disruption	Y	Security must be maintained during outages and crises.	**Not implemented**
A.5.30*	ICT readiness for business continuity	Y	RBI expects continuity of payment services; ICT recovery must be planned and tested.	**Partially implemented**
A.5.31	Legal, statutory, regulatory and contractual requirements	Y	Subject to DPDP Act, RBI PA guidelines, CERT-In Directions, IT Act and PCI DSS.	**Partially implemented**

Control	Name	Appl.	Justification	Implementation status
A.5.32	Intellectual property rights	Y	Software licences and open-source licence compliance.	Partially implemented
A.5.33	Protection of records	Y	Transaction and KYC records must be retained under RBI and PMLA requirements.	Partially implemented
A.5.34	Privacy and protection of PII	Y	SecurePay is a Data Fiduciary under the DPDP Act, 2023.	Partially implemented
A.5.35	Independent review of information security	Y	Independent assurance is required by partner banks and for certification.	Partially implemented
A.5.36	Compliance with policies, rules and standards for information security	Y	Managers must check compliance with security policies.	Not implemented
A.5.37	Documented operating procedures	Y	Deployment, settlement and recovery procedures must be documented.	Partially implemented
A.6.1	Screening	Y	Staff have access to payment and personal data.	Implemented
A.6.2	Terms and conditions of employment	Y	Employment contracts must state security responsibilities.	Implemented
A.6.3	Information security awareness, education and training	Y	People are the primary target of phishing and BEC.	Partially implemented
A.6.4	Disciplinary process	Y	A formal process is needed to act on security policy violations.	Partially implemented
A.6.5	Responsibilities after termination or change of employment	Y	Confidentiality duties and access removal on exit or role change.	Partially implemented
A.6.6	Confidentiality or non-disclosure agreements	Y	Employees, contractors and suppliers handle confidential data.	Implemented
A.6.7	Remote working	Y	Hybrid working model with company laptops.	Implemented
A.6.8	Information security event reporting	Y	Staff need a simple channel to report suspected events.	Not implemented
A.7.1	Physical security perimeters	Y	Office perimeter is provided by the building; data centre perimeter is inherited from AWS (verified via AWS assurance reports).	Implemented
A.7.2	Physical entry	Y	Office holds laptops and staff with access to production.	Implemented
A.7.3	Securing offices, rooms and facilities	Y	Office space must be protected against unauthorised access.	Implemented
A.7.4*	Physical security monitoring	Y	Office premises should be monitored for unauthorised physical access.	Partially implemented
A.7.5	Protecting against physical and environmental threats	Y	Office fire and environmental protection by building; data centre controls inherited from AWS.	Implemented
A.7.6	Working in secure areas	N	Not applicable: SecurePay operates no secure areas such as server rooms or data centres. Production runs in AWS, whose secure areas are covered by AWS's certified controls.	Not applicable
A.7.7	Clear desk and clear screen	Y	Screens may display personal and payment data in a shared building.	Partially implemented
A.7.8	Equipment siting and protection	Y	Limited on-site network equipment must be protected.	Implemented
A.7.9	Security of assets off-premises	Y	Laptops are routinely used off-premises.	Implemented
A.7.10	Storage media	Y	Removable media could be used to copy sensitive data.	Partially implemented
A.7.11	Supporting utilities	Y	Office power provided by building UPS and generator; data centre utilities inherited from AWS.	Implemented
A.7.12	Cabling security	N	Not applicable: SecurePay owns no cabling infrastructure. Office cabling is owned and managed by the facility provider and data centre cabling is inherited from AWS.	Not applicable
A.7.13	Equipment maintenance	Y	Laptops and network devices need maintenance under warranty.	Implemented
A.7.14	Secure disposal or re-use of equipment	Y	Laptops hold source code, credentials and data exports.	Not implemented
A.8.1	User end point devices	Y	Endpoints access production and personal data.	Implemented
A.8.2	Privileged access rights	Y	Admin access to cloud and databases gives full control of the platform.	Not implemented
A.8.3	Information access restriction	Y	Internal tools must restrict data shown by role.	Partially implemented
A.8.4	Access to source code	Y	Source code of the payment platform is a critical asset.	Partially implemented
A.8.5	Secure authentication	Y	High-risk applications and money-movement functions need strong authentication.	Partially implemented
A.8.6	Capacity management	Y	Payment volumes peak during sales events; capacity affects availability.	Implemented
A.8.7	Protection against malware	Y	Endpoints and uploaded KYC files can carry malware.	Partially implemented
A.8.8	Management of technical vulnerabilities	Y	Internet-facing payment services must be patched promptly.	Partially implemented
A.8.9*	Configuration management	Y	Cloud misconfiguration is a leading cause of breaches.	Partially implemented
A.8.10*	Information deletion	Y	DPDP Act requires erasure when the purpose is fulfilled.	Not implemented

Control	Name	Appl.	Justification	Implementation status
A.8.11*	Data masking	Y	Limits exposure of personal and card data to staff, vendors and test systems.	Partially implemented
A.8.12*	Data leakage prevention	Y	Customer data could be exfiltrated via email, SaaS or endpoints.	Not implemented
A.8.13	Information backup	Y	Transaction and settlement data must be recoverable.	Implemented
A.8.14	Redundancy of information processing facilities	Y	Payment services require high availability.	Partially implemented
A.8.15	Logging	Y	CERT-In requires 180-day log retention; PCI DSS requires 12 months.	Partially implemented
A.8.16*	Monitoring activities	Y	Attacks must be detected quickly to meet the 6-hour reporting window.	Not implemented
A.8.17	Clock synchronization	Y	Accurate timestamps are needed for forensics; CERT-In specifies NTP sources.	Partially implemented
A.8.18	Use of privileged utility programs	Y	Database and cloud CLI tools can bypass application controls.	Partially implemented
A.8.19	Installation of software on operational systems	Y	Production runs immutable containers deployed only through CI/CD.	Implemented
A.8.20	Networks security	Y	Cloud networks must protect payment services.	Implemented
A.8.21	Security of network services	Y	Relies on AWS networking, WAF and ISP services.	Partially implemented
A.8.22	Segregation of networks	Y	Separating production and non-production reduces PCI DSS scope.	Implemented
A.8.23*	Web filtering	Y	Reduces staff exposure to phishing and malicious websites.	Not implemented
A.8.24	Use of cryptography	Y	Payment and personal data must be encrypted in transit and at rest.	Implemented
A.8.25	Secure development life cycle	Y	SecurePay builds its payment platform in-house.	Partially implemented
A.8.26	Application security requirements	Y	Security requirements must be defined for payment features and APIs.	Partially implemented
A.8.27	Secure system architecture and engineering principles	Y	Architecture decisions determine PCI DSS scope and resilience.	Partially implemented
A.8.28*	Secure coding	Y	In-house code processes payments and personal data.	Partially implemented
A.8.29	Security testing in development and acceptance	Y	Releases must be security tested before going live.	Partially implemented
A.8.30	Outsourced development	N	Not applicable: all software is developed by in-house employees and no development is outsourced. To be revisited if development is outsourced in future.	Not applicable
A.8.31	Separation of development, test and production environments	Y	Separate AWS accounts protect production.	Implemented
A.8.32	Change management	Y	Frequent releases to a live payment platform.	Partially implemented
A.8.33	Test information	Y	Production personal data is currently copied to staging.	Not implemented
A.8.34	Protection of information systems during audit testing	Y	VAPT and audits are performed against live systems.	Partially implemented

Appendix C - Assumptions

ID	Assumption
AS-01	SecurePay Technologies is a fictional organisation. All facts about it, including incidents, findings and metrics, are assumed for the purpose of this exercise.
AS-02	The assessment reflects an assumed point-in-time state as at October 2026. No interviews, system access or evidence sampling were performed; 'evidence requested' lists what a real assessor would ask for.
AS-03	SecurePay holds RBI in-principle authorisation as an online Payment Aggregator and is working towards final authorisation.
AS-04	Card data is captured by a PCI DSS Level 1 partner processor's hosted fields and tokenised; SecurePay never stores full card numbers but remains in PCI DSS scope as a service provider. Formal PCI DSS v4.0.1 assessment is planned within 9 months.
AS-05	All production systems and payment data are hosted in AWS ap-south-1 (Mumbai) with backups in ap-south-2 (Hyderabad), meeting RBI payment data localisation.
AS-06	Physical and environmental controls for the data centre are inherited from AWS and validated through AWS assurance reports; they were not assessed directly.
AS-07	The support vendor 'SupportCo' is fictional and represents a typical small Indian BPO; 12 agents work from the vendor's premises.
AS-08	The DPDP Act, 2023 and the DPDP Rules, 2025 apply, with substantive obligations phased in; the assessment treats them as requirements SecurePay must be ready for.
AS-09	Risk ratings use SecurePay's assumed risk appetite: risks scored 12 or above must be treated; Medium risks may be accepted with documented CEO sign-off.
AS-10	Effort estimates are indicative person-days for internal staff and exclude licence costs; they assume an Information Security Manager is appointed within the first month.
AS-11	The 20 controls were selected for relevance to a cloud-hosted fintech; the remaining 73 controls have indicative SoA statuses only and were not assessed in detail.
AS-12	Control requirements are paraphrased in plain English for this exercise; refer to the licensed ISO/IEC 27001:2022 and ISO/IEC 27002:2022 texts for authoritative wording.

Appendix D - Glossary

Term	Meaning	Term	Meaning
AOC	Attestation of Compliance (PCI DSS)	MDR	Managed detection and response
ASV	Approved Scanning Vendor (PCI DSS)	MFA	Multi-factor authentication
BEC	Business email compromise	PA	Payment Aggregator (RBI-regulated)
CERT-In	Indian Computer Emergency Response Team	PCI DSS	Payment Card Industry Data Security Standard
CIS	Center for Internet Security	RPO / RTO	Recovery point / time objective
DPA	Data processing agreement	SAST / SCA	Static app. security testing / software composition analysis
DPDP	Digital Personal Data Protection Act, 2023	SIEM	Security information and event management
IDOR	Insecure direct object reference	SoA	Statement of Applicability
ISMS	Information Security Management System	VAPT	Vulnerability assessment and penetration testing